

Analysis Results

https://github.com/CHECK-MARX/Project_Shop_Site.git

Report Date

2026-05-18 04:35:48

Report Author

admin

Product Version

12.6

Confidentiality Note



This report is intended only for the person(s) or entity to which it is addressed and contains confidential and privileged information. If you are not the intended recipient, you must not view, use, copy, disclose, or otherwise disseminate this report or any part of it. Doing so is strictly prohibited, and may result in legal proceedings. If you received this in error, please notify the sender immediately and destroy any copies of this information.

1 Project Information	4
Dynamics by vulnerabilities	5
Scan History	7
2 Scan Information 2/2 2026-05-18 04:31:25	8
Scan Statistics	8
List of dependencies	10
Analysis Results	19
Scan Settings	125
3 Export Settings	126

01

Project Information

Project Name
https://github.com/CHECK-MARX/Project_Shop_Site.git
ID
1
URL
<https://github.com/CHECK-MARX/Pr...>
[Project in DerScanner](#)

Dynamics by vulnerabilities

Vulnerabilities are divided by severity level: critical, medium, low and info.

CRITICAL LEVEL

Likely to lead to compromise confidential data and violation of the integrity of the system.

MEDIUM LEVEL

May be less likely to lead to compromising confidential data and violating the integrity of the system, or are less serious security breaches.

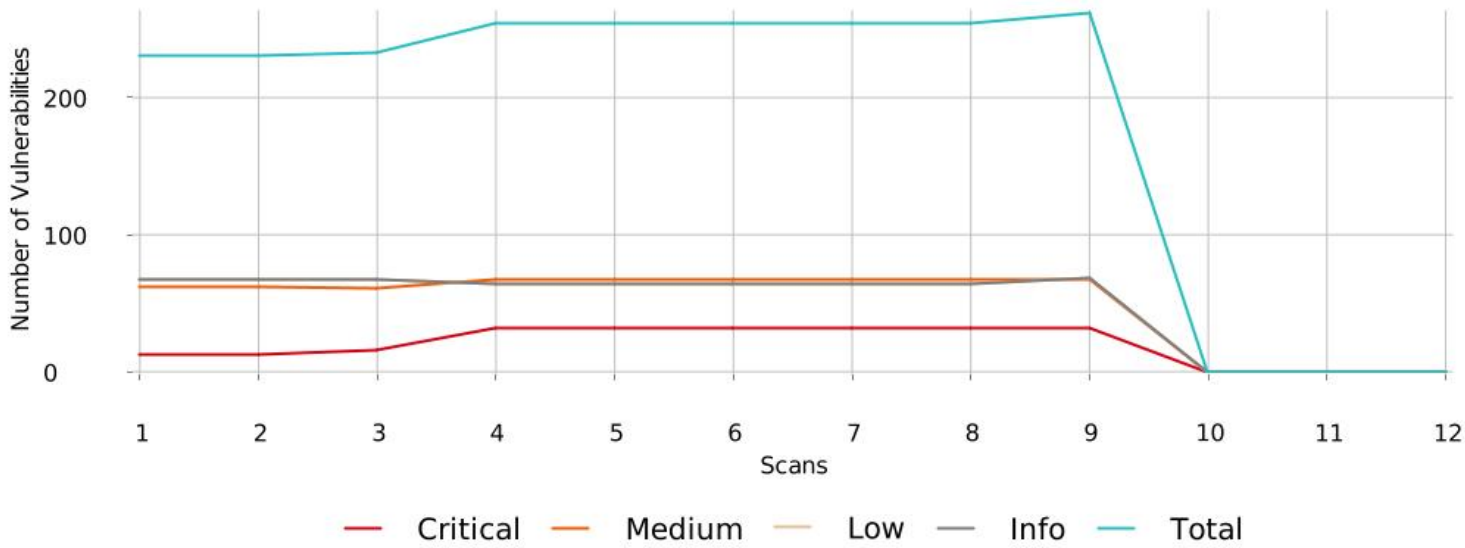
LOW LEVEL

Can become a potential security risk.

INFORMATION

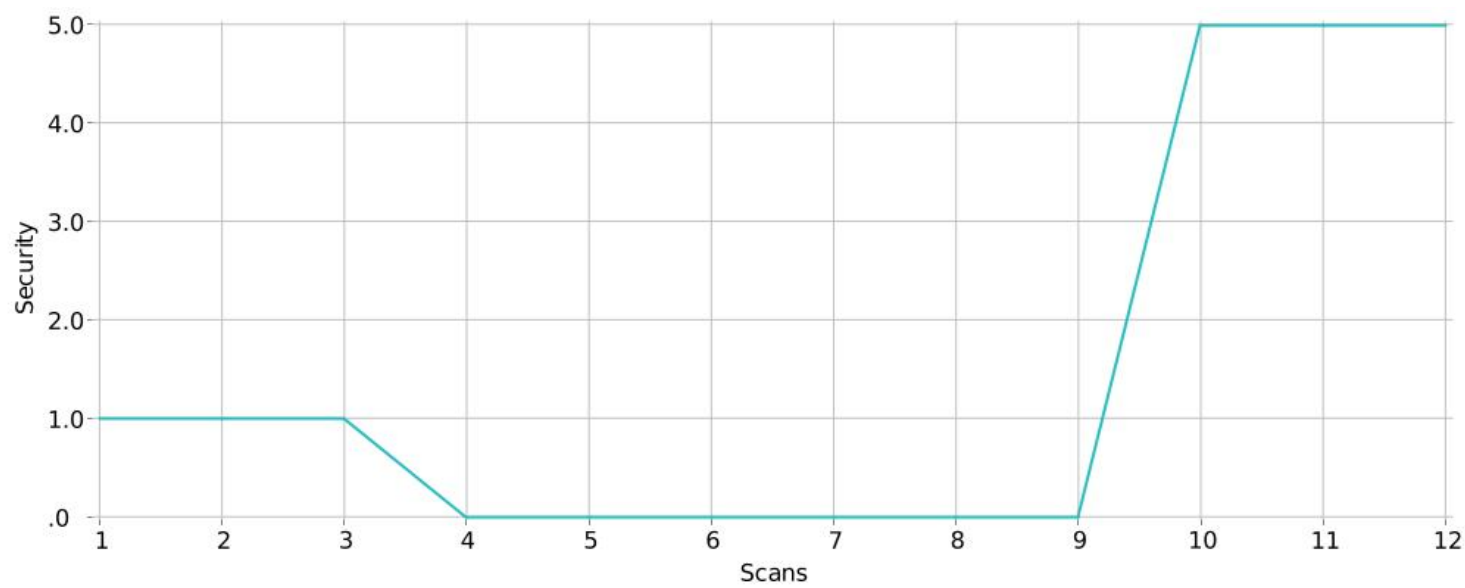
Signal a violation of good programming practice.

First of all, pay attention to vulnerabilities of critical and medium levels.



Dynamics by Security

Security is calculated based on the number of critical and medium level vulnerabilities. The impact of critical vulnerabilities is greater than that of medium level vulnerabilities, and does not take into account the amount of code. Medium level vulnerabilities are taken into account based on their frequency and total number of source code lines.



Scan History

	Date and Time	Status	Number of Dependencies			Number of Vulnerabilities					Security
			Vulnerable	Safe	Total	Critical	Medium	Low	Info	Total	
12/12	2026-05-18 04:31:25	success	229	45	274	32	68	64	90	254	0%
11/12	2026-05-18 04:26:28	success	237	21	258	32	67	69	94	262	0%
10/12	2026-05-14 23:59:58	success	229	45	274	32	68	64	90	254	0%
9/12	2026-05-14 04:05:49	success	229	45	274	32	68	64	90	254	0%
8/12	2026-05-13 07:22:13	success	229	45	274	32	68	64	90	254	0%
7/12	2026-05-12 11:50:50	success	229	45	274	32	68	64	90	254	0%
6/12	2026-04-07 11:08:58	success	229	45	274	16	61	67	89	233	1%
5/12	2026-04-07 10:07:54	error *	0	0	0	0	0	0	0	0	100%
4/12	2026-04-07 10:05:53	error *	0	0	0	0	0	0	0	0	100%
3/12	2026-04-07 09:56:42	error *	0	0	0	0	0	0	0	0	100%
2/12	2025-10-12 19:46:15	success	228	30	258	13	62	67	89	231	1%
1/12	2025-10-12 12:25:49	success	228	30	258	13	62	67	89	231	1%

* Errors occurred during scanning. For more information, go to the DerScanner interface.

02

Scan Information

2/2 2026-05-18 04:31:25

Scan Statistics

Status

success

Security

0%

Duration

0:02:03

Vulnerabilities

32

Critical

68

Medium

64

Low

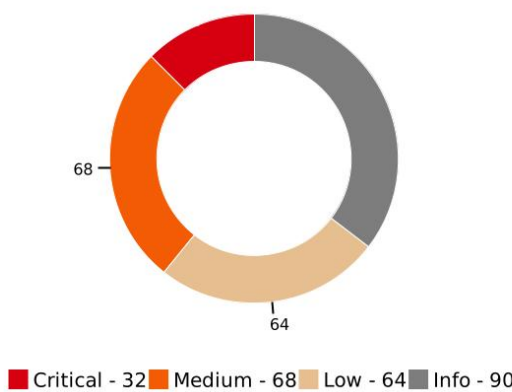
90

Info

254

Total

Diagram of identified vulnerabilities



Vulnerable Dependencies



List of dependencies

Vulnerabilities are displayed accordingly to export settings: **100 selected**
Actual: **100 of 254**

Vulnerable dependencies

Critical vulnerabilities	32
multer 1.4.5-lts.2 MIT	7
● CVE-2025-48997	Not processed
● CVE-2025-47935	Not processed
● CVE-2025-47944	Not processed
● CVE-2025-7338	Not processed
● CVE-2026-2359	Not processed
● CVE-2026-3304	Not processed
● CVE-2026-3520	Not processed
buffer-from 1.1.2 MIT	1
● Supply Chain Risk	Not processed
has-flag 3.0.0 MIT	1
● Supply Chain Risk	Not processed
indent-string 4.0.0 MIT	1
● Supply Chain Risk	Not processed
jws 3.2.2 MIT	1
● CVE-2025-65945	Not processed
lodash.includes 4.3.0 MIT	1
● Supply Chain Risk	Not processed

Critical vulnerabilities

lodash.isboolean 3.0.3 MIT	1
● Supply Chain Risk	Not processed
lodash.isinteger 4.0.4 MIT	1
● Supply Chain Risk	Not processed
lodash.isnumber 3.0.3 MIT	1
● Supply Chain Risk	Not processed
lodash.isplainobject 4.0.6 MIT	1
● Supply Chain Risk	Not processed
lodash.isstring 4.0.1 MIT	1
● Supply Chain Risk	Not processed
lodash.once 4.1.1 MIT	1
● Supply Chain Risk	Not processed
mimic-response 3.1.0 MIT	1
● Supply Chain Risk	Not processed
minimatch 3.1.2 ISC	3
● CVE-2026-26996	Not processed
● CVE-2026-27903	Not processed
● CVE-2026-27904	Not processed
node-pre-gyp 1.0.11 BSD-3-Clause	1
● Supply Chain Risk	Not processed
path-is-absolute 1.0.1 MIT	1
● Supply Chain Risk	Not processed
path-to-regexp 0.1.12 MIT	1
● CVE-2026-4867	Not processed

Critical vulnerabilities

picomatch 2.3.1 MIT

1

● CVE-2026-33671

Not processed

tar 6.2.1 ISC

5

● CVE-2026-26960

Not processed

● CVE-2026-24842

Not processed

● CVE-2026-29786

Not processed

● CVE-2026-23950

Not processed

● CVE-2026-31802

Not processed

xtend 4.0.2 MIT

1

● Supply Chain Risk

Not processed

Medium-level vulnerabilities

68

aggregate-error 3.1.0 MIT

1

● Supply Chain Risk

Not processed

ansi-regex 5.0.1 MIT

1

● Supply Chain Risk

Not processed

binary-extensions 2.3.0 MIT

1

● Supply Chain Risk

Not processed

brace-expansion 1.1.12 MIT

1

● CVE-2026-33750

Not processed

clean-stack 2.2.0 MIT

1

● Supply Chain Risk

Not processed

color-support 1.1.3 ISC

1

● Supply Chain Risk

Not processed

concat-map 0.0.1 MIT

1

Medium-level vulnerabilities

concat-map 0.0.1 MIT

● Supply Chain Risk

Not processed

console-control-strings 1.1.0 ISC

1

● Supply Chain Risk

Not processed

core-util-is 1.0.3 MIT

1

● Supply Chain Risk

Not processed

debug 2.6.9 MIT

1

● Supply Chain Risk

Not processed

decompress-response 6.0.0 MIT

1

● Supply Chain Risk

Not processed

deep-extend 0.6.0 MIT

1

● Supply Chain Risk

Not processed

ee-first 1.1.1 MIT

1

● Supply Chain Risk

Not processed

encoding 0.1.13 MIT

1

● Supply Chain Risk

Not processed

env-paths 2.2.1 MIT

1

● Supply Chain Risk

Not processed

err-code 2.0.3 MIT

1

● Supply Chain Risk

Not processed

expand-template 2.0.3 MIT,WTFPL

1

● Supply Chain Risk

Not processed

express 4.21.2 MIT

1

● CVE-2024-51999

Not processed

Medium-level vulnerabilities

file-uri-to-path 1.0.0 MIT	1
● Supply Chain Risk	Not processed
fs-constants 1.0.0 MIT	1
● Supply Chain Risk	Not processed
fsevents 2.3.3 MIT	1
● Supply Chain Risk	Not processed
glob 7.2.3 ISC	1
● Supply Chain Risk	Not processed
gopd 1.2.0 MIT	1
● Supply Chain Risk	Not processed
has-unicode 2.0.1 ISC	1
● Supply Chain Risk	Not processed
hasown 2.0.2 MIT	1
● Supply Chain Risk	Not processed
humanize-ms 1.2.1 MIT	1
● Supply Chain Risk	Not processed
ieee754 1.2.1 BSD-3-Clause	1
● Supply Chain Risk	Not processed
ignore-by-default 1.0.1 ISC	1
● Supply Chain Risk	Not processed
imurmurhash 0.1.4 MIT	1
● Supply Chain Risk	Not processed
is-binary-path 2.1.0 MIT	1
● Supply Chain Risk	Not processed

Medium-level vulnerabilities

is-extglob 2.1.1 MIT	1
● Supply Chain Risk	Not processed
is-fullwidth-code-point 3.0.0 MIT	1
● Supply Chain Risk	Not processed
is-glob 4.0.3 MIT	1
● Supply Chain Risk	Not processed
is-lambda 1.0.1 MIT	1
● Supply Chain Risk	Not processed
make-dir 3.1.0 MIT	1
● Supply Chain Risk	Not processed
merge-descriptors 1.0.3 MIT	1
● Supply Chain Risk	Not processed
minipass-flush 1.0.5 ISC	1
● Supply Chain Risk	Not processed
minipass-sized 1.0.3 ISC	1
● Supply Chain Risk	Not processed
mkdirp-classic 0.5.3 MIT	1
● Supply Chain Risk	Not processed
napi-build-utils 2.0.0 MIT	1
● Supply Chain Risk	Not processed
normalize-path 3.0.0 MIT	1
● Supply Chain Risk	Not processed
object-assign 4.1.1 MIT	1
● Supply Chain Risk	Not processed

Medium-level vulnerabilities

p-map 4.0.0 MIT	1
● Supply Chain Risk	Not processed
picomatch 2.3.1 MIT	1
● CVE-2026-33672	Not processed
process-nextick-args 2.0.1 MIT	1
● Supply Chain Risk	Not processed
promise-inflight 1.0.1 ISC	1
● Supply Chain Risk	Not processed
pstree.remy 1.1.8 MIT	1
● Supply Chain Risk	Not processed
random-bytes 1.0.0 MIT	1
● Supply Chain Risk	Not processed
safer-buffer 2.1.2 MIT	1
● Supply Chain Risk	Not processed
set-blocking 2.0.0 ISC	1
● Supply Chain Risk	Not processed
setprototypeof 1.2.0 ISC	1
● Supply Chain Risk	Not processed
simple-concat 1.0.1 MIT	1
● Supply Chain Risk	Not processed
simple-get 4.0.1 MIT	1
● Supply Chain Risk	Not processed
string-width 4.2.3 MIT	1
● Supply Chain Risk	Not processed

Medium-level vulnerabilities

strip-ansi 6.0.1 MIT	1
● Supply Chain Risk	Not processed
strip-json-comments 2.0.1 MIT	1
● Supply Chain Risk	Not processed
supports-color 5.5.0 MIT	1
● Supply Chain Risk	Not processed
tar 6.2.1 ISC	1
● CVE-2026-23745	Not processed
tar-stream 2.2.0 MIT	1
● Supply Chain Risk	Not processed
toidentifier 1.0.1 MIT	1
● Supply Chain Risk	Not processed
tunnel-agent 0.6.0 Apache-2.0	1
● Supply Chain Risk	Not processed
typedarray 0.0.6 MIT	1
● Supply Chain Risk	Not processed
uid-safe 2.1.5 MIT	1
● Supply Chain Risk	Not processed
unpipe 1.0.0 MIT	1
● Supply Chain Risk	Not processed
util-deprecate 1.0.2 MIT	1
● Supply Chain Risk	Not processed
utils-merge 1.0.1 MIT	1
● Supply Chain Risk	Not processed

Medium-level vulnerabilities

whatwg-url 5.0.0 MIT

1

● Supply Chain Risk

Not processed

wrappy 1.0.2 ISC

1

● Supply Chain Risk

Not processed

Low-level vulnerabilities

0

Info-level vulnerabilities

0

Analysis Results

multer 1.4.5-lts.2 MIT

D ** T ***

Dependencies found: 7

Dependencies:

- xtend 4.0.2
- object-assign 4.1.1
- append-field 1.0.0
- concat-stream 1.6.2
- mkdirp 0.5.6
- busboy 1.6.0
- type-is 1.6.18

Vulnerabilities

CVE-2025-48997

Level **Critical**

Status Not processed

Classification

CVE	CVE-2025-48997
CWE	CWE-248
GitHub Security Advisory	GHSA-g5hg-p3ph-g8qg
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

Multer is a node.js middleware for handling `multipart/form-data`. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.1 allows an attacker to trigger a Denial of Service (DoS) by sending an upload file request with an empty string field name. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to `2.0.1` to receive a patch. No known workarounds are available.

Recommendations

Vulnerability affects multer [1.4.4-lts.1,2.0.1). Upgrade multer to 2.0.1 or higher.

Links

<https://nvd.nist.gov/vuln/detail/CVE-2025-48997>
<https://github.com/expressjs/multer/security/advisories/GHSA-g5hg-p3ph-g8qg>
<https://github.com/advisories/GHSA-g5hg-p3ph-g8qg>
<https://github.com/expressjs/multer/commit/35a3272b611945155e046dd5cef11088587635e9>
<https://github.com/expressjs/multer/issues/1233>
<https://github.com/expressjs/multer>
<https://github.com/expressjs/multer/pull/1256>

CVE-2025-47935

Level **Critical**

Status Not processed

Classification

CVE	CVE-2025-47935
CWE	CWE-401
GitHub Security Advisory	GHSA-44fp-w29j-9vj5
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

Multer is a node.js middleware for handling `multipart/form-data`. Versions prior to 2.0.0 are vulnerable to a resource exhaustion and memory leak issue due to improper stream handling. When the HTTP request stream emits an error, the internal `busboy` stream is not closed, violating Node.js stream safety guidance. This leads to unclosed streams accumulating over time, consuming memory and file descriptors. Under sustained or repeated failure conditions, this can result in denial of service, requiring manual server restarts to recover. All users of Multer handling file uploads are potentially impacted. Users should upgrade to 2.0.0 to receive a patch. No known workarounds are available.

Recommendations

Vulnerability affects multer [0,2.0.0). Upgrade multer to 2.0.0 or higher.

Links

https://nvd.nist.gov/vuln/detail/CVE-2025-47935
https://github.com/expressjs/multer/security/advisories/GHSA-44fp-w29j-9vj5
https://github.com/advisories/GHSA-44fp-w29j-9vj5
https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665
https://github.com/expressjs/multer
https://github.com/expressjs/multer/pull/1120

CVE-2025-47944

LevelCritical

StatusNot processed

Classification

CVE	CVE-2025-47944
CWE	CWE-248
GitHub Security Advisory	GHSA-4pg4-qvpc-4q3h
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

Multer is a node.js middleware for handling `multipart/form-data`. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.0 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.0 to receive a patch. No known workarounds are available.

Recommendations

Vulnerability affects multer [1.4.4-lts.1,2.0.0). Upgrade multer to 2.0.0 or higher.

Links

https://nvd.nist.gov/vuln/detail/CVE-2025-47944
https://github.com/expressjs/multer/commit/2c8505f207d923dd8de13a9f93a4563e59933665
https://github.com/expressjs/multer/security/advisories/GHSA-4pg4-qvpc-4q3h

<https://github.com/expressjs/multer/issues/1176>
<https://github.com/expressjs/multer>
<https://github.com/advisories/GHSA-4pg4-qvpc-4q3h>

CVE-2025-7338

Level **Critical**

Status Not processed

Classification

CVE	CVE-2025-7338
CWE	CWE-248
GitHub Security Advisory	GHSA-fjgf-rc76-4x9p
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

Multer is a node.js middleware for handling `multipart/form-data`. A vulnerability that is present starting in version 1.4.4-lts.1 and prior to version 2.0.2 allows an attacker to trigger a Denial of Service (DoS) by sending a malformed multi-part upload request. This request causes an unhandled exception, leading to a crash of the process. Users should upgrade to version 2.0.2 to receive a patch. No known workarounds are available.

Recommendations

Vulnerability affects multer [1.4.4-lts.1,2.0.2). Upgrade multer to 2.0.2 or higher.

Links

<https://github.com/expressjs/multer/commit/adfeaf669f0e7fe953eab191a762164a452d143b>
<https://github.com/advisories/GHSA-fjgf-rc76-4x9p>
<https://cna.openjsf.org/security-advisories.html>
<https://github.com/expressjs/multer/security/advisories/GHSA-fjgf-rc76-4x9p>
<https://nvd.nist.gov/vuln/detail/CVE-2025-7338>
<https://github.com/expressjs/multer>

CVE-2026-2359

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-2359
CWE	CWE-772,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-v52c-386h-88mc
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

A vulnerability in Multer versions < 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by dropping connection during file upload, potentially causing resource exhaustion.

Recommendations

Vulnerability affects multer [0,2.1.0). Upgrade multer to 2.1.0 or higher.

Links

<https://github.com/expressjs/multer>
<https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc>
<https://nvd.nist.gov/vuln/detail/CVE-2026-2359>
<https://github.com/advisories/GHSA-v52c-386h-88mc>
<https://cna.openjsf.org/security-advisories.html>
<https://github.com/expressjs/multer/security/advisories/GHSA-v52c-386h-88mc>
<https://cna.openjsf.org/security-advisories.html>
<https://www.cve.org/CVERecord?id=CVE-2026-2359>
<https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab>
<https://www.cve.org/CVERecord?id=CVE-2026-2359>
<https://github.com/expressjs/multer>
<https://nvd.nist.gov/vuln/detail/CVE-2026-2359>
<https://github.com/expressjs/multer/commit/ccc0fe0e64150c4f42ccf6654165c0d66b9adab>

CVE-2026-3304

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-3304

CWE	CWE-459,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-xf7r-hgr6-v32p
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

A vulnerability in Multer versions < 2.1.0 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing resource exhaustion.

Recommendations

Vulnerability affects multer [0,2.1.0). Upgrade multer to 2.1.0 or higher.

Links

<https://github.com/expressjs/multer>
<https://github.com/expressjs/multer/security/advisories/GHSA-xf7r-hgr6-v32p>
<https://nvd.nist.gov/vuln/detail/CVE-2026-3304>
<https://www.cve.org/CVERecord?id=CVE-2026-3304>
<https://github.com/expressjs/multer/security/advisories/GHSA-xf7r-hgr6-v32p>
<https://github.com/advisories/GHSA-xf7r-hgr6-v32p>
<https://cna.openjsf.org/security-advisories.html>
<https://www.cve.org/CVERecord?id=CVE-2026-3304>
<https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee>
<https://cna.openjsf.org/security-advisories.html>
<https://nvd.nist.gov/vuln/detail/CVE-2026-3304>
<https://github.com/expressjs/multer>
<https://github.com/expressjs/multer/commit/739919097dde3921ec31b930e4b9025036fa74ee>

CVE-2026-3520

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-3520
CWE	CWE-674,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-5528-5vmv-3xc2
Go Vulnerability Database	null

Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

A vulnerability in Multer versions < 2.1.1 allows an attacker to trigger a Denial of Service (DoS) by sending malformed requests, potentially causing stack overflow.

Recommendations

Vulnerability affects multer [0,2.1.1). Upgrade multer to 2.1.1 or higher.

Links

<https://nvd.nist.gov/vuln/detail/CVE-2026-3520>
<https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2>
<https://github.com/expressjs/multer>
<https://nvd.nist.gov/vuln/detail/CVE-2026-3520>
<https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752>
<https://github.com/expressjs/multer/security/advisories/GHSA-5528-5vmv-3xc2>
<https://github.com/expressjs/multer/commit/7e66481f8b2e6c54b982b34c152479e096ce2752>
<https://www.cve.org/CVERecord?id=CVE-2026-3520>
<https://cna.openjsf.org/security-advisories.html>
<https://github.com/advisories/GHSA-5528-5vmv-3xc2>
<https://github.com/expressjs/multer>
<https://cna.openjsf.org/security-advisories.html>
<https://www.cve.org/CVERecord?id=CVE-2026-3520>

aggregate-error 3.1.0 MIT

 ***

Dependencies found: 2

Dependencies:

■ indent-string 4.0.0

■ clean-stack 2.2.0

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 24.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	88
Authorship assessment	0
Interest in safety	no
Community activity	20
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

ansi-regex 5.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 42.

❗ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	90
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

binary-extensions 2.3.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 32.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	72
Authorship assessment	0
Interest in safety	no
Community activity	60
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

brace-expansion 1.1.12 MIT

T***

Dependencies found: 2

Dependencies:

- concat-map 0.0.1
- balanced-match 1.0.2

Vulnerabilities

CVE-2026-33750

Level	Medium
Status	Not processed
Classification	

CVE	CVE-2026-33750
CWE	CWE-400 , CWE-937 , CWE-1035
GitHub Security Advisory	GHSA-f886-m6hf-6m8v
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

A brace pattern with a zero step value (e.g., `{1..2..0}`) causes the sequence generation loop to run indefinitely, making the process hang for seconds and allocate heaps of memory.

The loop in question:

<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L184>

`test()` is one of

<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L107-L113>

The increment is computed as `Math.abs(0) = 0`, so the loop variable never advances. On a test machine, the process hangs for about 3.5 seconds and allocates roughly 1.9 GB of memory before throwing a `RangeError`. Setting `max` to any value has no effect because the limit is only checked at the output combination step, not during sequence generation.

This affects any application that passes untrusted strings to `expand()`, or by error sets a step value of `0`. That includes tools built on `minimatch/glob` that resolve patterns from CLI arguments or config files. The input needed is just 10 bytes.

Recommendations

Vulnerability affects brace-expansion [0,1.1.13). Upgrade brace-expansion to 1.1.13 or higher.

Links

<https://github.com/juliangruber/brace-expansion/pull/97>
<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L107-L113>
<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L184>
<https://github.com/juliangruber/brace-expansion/commit/7fd684f89fdde3549563d0a6522226a9189472a2>
<https://github.com/juliangruber/brace-expansion/issues/98>
<https://github.com/juliangruber/brace-expansion/pull/96>
<https://github.com/juliangruber/brace-expansion/commit/b9cacd9e55e7a1fa588fe4b7bb1159d52f1d902a>
<https://github.com/juliangruber/brace-expansion>
<https://github.com/juliangruber/brace-expansion/security/advisories/GHSA-f886-m6hf-6m8v>
<https://github.com/juliangruber/brace-expansion/pull/95>
<https://github.com/advisories/GHSA-f886-m6hf-6m8v>
<https://github.com/juliangruber/brace-expansion/commit/311ac0d54994158c0a384e286a7d6cbb17ee8ed5>
<https://nvd.nist.gov/vuln/detail/CVE-2026-33750>
<https://github.com/juliangruber/brace-expansion/commit/311ac0d54994158c0a384e286a7d6cbb17ee8ed5>
<https://github.com/juliangruber/brace-expansion/security/advisories/GHSA-f886-m6hf-6m8v>
<https://github.com/juliangruber/brace-expansion/pull/96>
<https://github.com/juliangruber/brace-expansion/commit/b9cacd9e55e7a1fa588fe4b7bb1159d52f1d902a>
<https://github.com/juliangruber/brace-expansion/pull/95>
<https://nvd.nist.gov/vuln/detail/CVE-2026-33750>
<https://github.com/juliangruber/brace-expansion>
<https://github.com/juliangruber/brace-expansion/commit/7fd684f89fdde3549563d0a6522226a9189472a2>
<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L184>
<https://github.com/juliangruber/brace-expansion/blob/daa71bcb4a30a2df9bcb7f7b8daaf2ab30e5794a/src/index.ts#L107-L113>
<https://github.com/juliangruber/brace-expansion/pull/97>
<https://github.com/juliangruber/brace-expansion/issues/98>

buffer-from 1.1.2 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 10.

❗ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	48
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

clean-stack 2.2.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 42.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	94
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

color-support 1.1.3 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	42
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

concat-map 0.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	12
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

console-control-strings 1.1.0 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 50.

Metrics	Security
Popularity	48
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

core-util-is 1.0.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	72
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

debug 2.6.9 MIT

T***

Dependencies found: 1

Dependencies:

ms 2.0.0

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 30.

❗ Unreliable contributors. Users `medikoo`, `sindresorhus` has expressed strong political opinions. User `medikoo` seen in intentional malware implementation.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	100
Recently created library	no
First version suspiciously high	no
Only project by this developer	yes
% of pull requests violate the 2-person review requirement	0.6 %

decompress-response 6.0.0 MIT

T***

Dependencies found: 1

Dependencies:

■ mimic-response 3.1.0

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 32.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	66
Authorship assessment	0
Interest in safety	no
Community activity	60
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

deep-extend 0.6.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 58.

Metrics	Security
Popularity	86
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

ee-first 1.1.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	60
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

encoding 0.1.13 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	74
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

env-paths 2.2.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 44.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	98
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

err-code 2.0.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	46
Authorship assessment	100
Interest in safety	no
Community activity	20
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

expand-template 2.0.3 MIT,WTFPL

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	40
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	28.6 %

express 4.21.2 MIT

T***

Dependencies found: 30

Dependencies:

- path-to-regexp 0.1.12
- debug 2.6.9
- merge-descriptors 1.0.3
- setprototypeof 1.2.0
- utils-merge 1.0.1

- qs 6.13.0
- cookie-signature 1.0.6
- depd 2.0.0
- escape-html 1.0.3
- etag 1.8.1
- safe-buffer 5.2.1
- accepts 1.3.8
- array-flatten 1.1.1
- body-parser 1.20.3
- content-disposition 0.5.4
- content-type 1.0.5
- encodeurl 2.0.0
- finalhandler 1.3.1
- fresh 0.5.2
- http-errors 2.0.0
- methods 1.1.2
- on-finished 2.4.1
- parseurl 1.3.3
- proxy-addr 2.0.7
- range-parser 1.2.1
- send 0.19.0
- serve-static 1.16.2
- statuses 2.0.1
- type-is 1.6.18
- vary 1.1.2

Vulnerabilities

CVE-2024-51999

Level

Medium

Status

Not processed

Classification

CVE	CVE-2024-51999
CWE	CWE-915,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-pj86-cfqh-vqx6
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

This advisory has been marked as False Positive and removed.

Recommendations

Vulnerability affects express [0,4.22.0). Upgrade express to 4.22.0 or higher.

Links

- https://github.com/expressjs/express/releases/tag/4.22.0
- https://github.com/expressjs/express/releases/tag/4.22.0
- https://github.com/expressjs/express
- https://github.com/expressjs/express
- https://nvd.nist.gov/vuln/detail/CVE-2024-51999
- https://nvd.nist.gov/vuln/detail/CVE-2024-51999
- https://github.com/expressjs/express/commit/2f64f68c37c64ae333e41ff38032d21860f22255
- https://github.com/expressjs/express/commit/2f64f68c37c64ae333e41ff38032d21860f22255
- https://github.com/expressjs/express/security/advisories/GHSA-pj86-cfqh-vqx6
- https://github.com/expressjs/express/releases/tag/v5.2.0
- https://github.com/expressjs/express/releases/tag/v5.2.0
- https://github.com/expressjs/express/security/advisories/GHSA-pj86-cfqh-vqx6
- https://github.com/advisories/GHSA-pj86-cfqh-vqx6

file-uri-to-path 1.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 50.

Metrics	Security
Popularity	50
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

fs-constants 1.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 46.

Metrics	Security
Popularity	28
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

fsevents 2.3.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	100
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	yes
% of pull requests violate the 2-person review requirement	2.5 %

glob 7.2.3 ISC

T***

Dependencies found: 6

Dependencies:

-   minimatch 3.1.2
-  path-is-absolute 1.0.1
-  fs.realpath 1.0.0
-  once 1.4.0
-  inflight 1.0.6

 inherits 2.0.4

Vulnerabilities

Supply Chain Risk

Level

Medium

Status

Not processed

Description

Dependency score: 50.

 Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	100
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	15.6 %

gopd 1.2.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	12
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

has-flag 3.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 14.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	72
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

has-unicode 2.0.1 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 50.

Metrics	Security
Popularity	46
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

hasown 2.0.2 MIT

T***

Dependencies found: 1

Dependencies:

■ function-bind 1.1.2

Vulnerabilities

Supply Chain Risk

Level Medium

Status Not processed

Description

Dependency score: 54.

❗ There might be a typo, library name resembles hjson.

Metrics	Security
Popularity	6
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

humanize-ms 1.2.1 MIT

T***

Dependencies found: 1

Dependencies:

■ ms 2.0.0

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 50.

Metrics	Security
Popularity	48
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

ieee754 1.2.1 BSD-3-Clause

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	78
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	64.3 %

ignore-by-default 1.0.1 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	44
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	28.6 %

imurmurhash 0.1.4 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	70
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

indent-string 4.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 14.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	74
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

is-binary-path 2.1.0 MIT

T***

Dependencies found: 1

Dependencies:

binary-extensions 2.3.0

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 24.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	58
Authorship assessment	0
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

is-extglob 2.1.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	44
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

is-fullwidth-code-point 3.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 24.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	60
Authorship assessment	0
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

is-glob 4.0.3 MIT

T***

Dependencies found: 1

Dependencies:

■ is-extglob 2.1.1

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	70
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	16.7 %

is-lambda 1.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	44
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

jws 3.2.2 MIT

T***

Dependencies found: 2

Dependencies:

- jwa 1.4.2
- safe-buffer 5.2.1

Vulnerabilities

CVE-2025-65945

Level	Critical
Status	Not processed
Classification	

CVE	CVE-2025-65945
CWE	CWE-347
GitHub Security Advisory	GHSA-869p-cjfg-cm3x
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

auth0/node-jws is a JSON Web Signature implementation for Node.js. In versions 3.2.2 and earlier and version 4.0.0, auth0/node-jws has an improper signature verification vulnerability when using the HS256 algorithm under specific conditions. Applications are affected when they use the `jws.createVerify()` function for HMAC algorithms and use user-provided data from the JSON Web Signature protected header or payload in HMAC secret lookup routines, which can allow attackers to bypass signature verification. This issue has been patched in versions 3.2.3 and 4.0.1.

Recommendations

Vulnerability affects jws [0,3.2.3). Upgrade jws to 3.2.3 or higher.

Links

<https://github.com/auth0/node-jws>
<https://github.com/auth0/node-jws/security/advisories/GHSA-869p-cjfg-cm3x>
<https://github.com/auth0/node-jws/commit/34c45b2c04434f925b638de6a061de9339c0ea2e>
<https://github.com/auth0/node-jws/commit/4f6e73f24df42f07d632dec6431ade8eda8d11a6>
<https://github.com/auth0/node-jws/releases/tag/v4.0.1>
<https://github.com/auth0/node-jws/releases/tag/v3.2.3>
<https://github.com/advisories/GHSA-869p-cjfg-cm3x>
<https://nvd.nist.gov/vuln/detail/CVE-2025-65945>

lodash.includes 4.3.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 0.

- ❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.isboolean 3.0.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.isinteger 4.0.4 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.isnumber 3.0.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.isplainobject 4.0.6 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.isstring 4.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

lodash.once 4.1.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: **0**.

❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

make-dir 3.1.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 38.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	60
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

merge-descriptors 1.0.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 40.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	80
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

mimic-response 3.1.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 18.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	62
Authorship assessment	0
Interest in safety	no
Community activity	20
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

minimatch 3.1.2 ISC

T***

Dependencies found: 1

Dependencies:

brace-expansion 1.1.12

Vulnerabilities

CVE-2026-26996

Level	Critical
Status	Not processed
Classification	

CVE	CVE-2026-26996
CWE	CWE-1333,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-3ppc-4f35-3m26
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

`minimatch` is vulnerable to Regular Expression Denial of Service (ReDoS) when a glob pattern contains many consecutive `\*` wildcards followed by a literal character that doesn't appear in the test string. Each `\*` compiles to a separate `[^]\*` regex group, and when the match fails, V8's regex engine backtracks exponentially across all possible splits.

The time complexity is $O(4^N)$ where N is the number of `\*` characters. With $N=15$, a single `minimatch()` call takes ~2 seconds. With $N=34$, it hangs effectively forever.

Recommendations

Vulnerability affects minimatch [0,3.1.3). Upgrade minimatch to 3.1.3 or higher.

Links

<https://nvd.nist.gov/vuln/detail/CVE-2026-26996>
<https://github.com/isaacs/minimatch>
<https://nvd.nist.gov/vuln/detail/CVE-2026-26996>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>
<https://github.com/isaacs/minimatch>
<https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
<https://github.com/isaacs/minimatch/commit/2e111f3a79abc00fa73110195de2c0f2351904f5>
<https://github.com/advisories/GHSA-3ppc-4f35-3m26>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-3ppc-4f35-3m26>

CVE-2026-27903

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-27903
CWE	CWE-407,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-7r86-cg39-jmmj
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

``matchOne()`` performs unbounded recursive backtracking when a glob pattern contains multiple non-adjacent ``**`` (GLOBSTAR) segments and the input path does not match. The time complexity is $O(C(n, k))$ -- binomial -- where ``n`` is the number of path segments and ``k`` is the number of globstars. With $k=11$ and $n=30$, a call to the default ``minimatch()`` API stalls for roughly 5 seconds. With $k=13$, it exceeds 15 seconds. No memoization or call budget exists to bound this behavior.

Recommendations

Links

<https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
<https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>
<https://github.com/isaacs/minimatch/commit/0bf499aa45f5059b56809cc3b75ff3eafeb8d748>
<https://github.com/isaacs/minimatch>
<https://nvd.nist.gov/vuln/detail/CVE-2026-27903>
<https://github.com/advisories/GHSA-7r86-cg39-jmmj>
<https://github.com/isaacs/minimatch>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-7r86-cg39-jmmj>

CVE-2026-27904

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-27904
CWE	CWE-1333 , CWE-937 , CWE-1035
GitHub Security Advisory	GHSA-23c5-xmqv-rm74
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

Nested ``*()`` extglobs produce regexps with nested unbounded quantifiers (e.g. ``(?:?:a|b)*``), which exhibit catastrophic backtracking in V8. With a 12-byte pattern ``*(*(*a|b))`` and an 18-byte non-matching input, ``minimatch()`` stalls for over 7 seconds. Adding a single nesting level or a few input characters pushes this to minutes. This is the most severe finding: it is triggered by the default ``minimatch()`` API with no special options, and the minimum viable pattern is only 12 bytes. The same issue affects ``+()`` extglobs equally.

Recommendations

Links

<https://nvd.nist.gov/vuln/detail/CVE-2026-27904>
<https://github.com/advisories/GHSA-23c5-xmqv-rm74>
<https://github.com/isaacs/minimatch>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>
<https://nvd.nist.gov/vuln/detail/CVE-2026-27904>
<https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>
<https://github.com/isaacs/minimatch>
<https://github.com/isaacs/minimatch/commit/11d0df6165d15a955462316b26d52e5efae06fce>
<https://github.com/isaacs/minimatch/security/advisories/GHSA-23c5-xmqv-rm74>

minipass-flush 1.0.5 ISC

T***

Dependencies found: 1

Dependencies:

■ minipass 3.3.6

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	16
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

minipass-sized 1.0.3 ISC

T***

Dependencies found: 1

Dependencies:

■ minipass 3.3.6

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	18
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

mkdirp-classic 0.5.3 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 42.

Metrics	Security
Popularity	12
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

napi-build-utils 2.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 44.

Metrics	Security
Popularity	18
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

node-pre-gyp 1.0.11 BSD-3-Clause

T***

Dependencies found: 9

Dependencies:

- tar 6.2.1
- make-dir 3.1.0
- detect-libc 2.1.0
- https-proxy-agent 5.0.1
- node-fetch 2.7.0

- nopt 5.0.0
- npmlog 5.0.1
- rimraf 3.0.2
- semver 7.7.2

Vulnerabilities

Supply Chain Risk

Level **Critical**

Status Not processed

Description

Dependency score: 0.

- ❗ This library uses statistics from another library. The library uses another's statistics to falsify its trustworthiness and adoption scope..

Metrics	Security
Popularity	0
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no

% of pull requests violate the 2-person review requirement	0.0 %
--	-------

normalize-path 3.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	72
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

object-assign 4.1.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 26.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	20
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	6.7 %

p-map 4.0.0 MIT

T***

Dependencies found: 1

Dependencies:

■ aggregate-error 3.1.0

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 44.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

path-is-absolute 1.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 12.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	56
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

path-to-regexp 0.1.12 MIT

Dependencies not found

Vulnerabilities

CVE-2026-4867

Level

Critical

Status

Not processed

Classification

CVE	CVE-2026-4867
CWE	CWE-1333,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-37ch-88jc-xwx2
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

A bad regular expression is generated any time you have three or more parameters within a single segment, separated by something that is not a period (`. `). For example, `/a-b:c` or `/a-b:c:d`. The backtrack protection added in `path-to-regexp@0.1.12` only prevents ambiguity for two parameters. With three or more, the generated lookahead does not block single separator characters, so capture groups overlap and cause catastrophic backtracking.

Recommendations

Vulnerability affects path-to-regexp [0,0.1.13). Upgrade path-to-regexp to 0.1.13 or higher.

Links

- https://github.com/pillarjs/path-to-regexp
- https://github.com/advisories/GHSA-9wv6-86v2-598j
- https://github.com/advisories/GHSA-9wv6-86v2-598j
- https://cna.openjsf.org/security-advisories.html
- https://nvd.nist.gov/vuln/detail/CVE-2026-4867
- https://github.com/advisories/GHSA-37ch-88jc-xwx2
- https://github.com/pillarjs/path-to-regexp/security/advisories/GHSA-37ch-88jc-xwx2
- https://github.com/pillarjs/path-to-regexp/releases/tag/v.0.1.13
- https://github.com/pillarjs/path-to-regexp/security/advisories/GHSA-37ch-88jc-xwx2
- https://github.com/pillarjs/path-to-regexp
- https://nvd.nist.gov/vuln/detail/CVE-2026-4867
- https://blakeembrey.com/posts/2024-09-web-redos
- https://github.com/pillarjs/path-to-regexp/releases/tag/v.0.1.13
- https://cna.openjsf.org/security-advisories.html
- https://blakeembrey.com/posts/2024-09-web-redos

picomatch 2.3.1 MIT

Dependencies not found

Vulnerabilities

CVE-2026-33672

Level	Medium
Status	Not processed
Classification	

CVE	CVE-2026-33672
CWE	CWE-1321 , CWE-937 , CWE-1035
GitHub Security Advisory	GHSA-3v7f-55p6-f55p
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

picomatch is vulnerable to a **method injection vulnerability (CWE-1321)** affecting the ``POSIX_REGEX_SOURCE`` object. Because the object inherits from ``Object.prototype``, specially crafted POSIX bracket expressions (e.g., ``[:constructor:]``) can reference inherited method names. These methods are implicitly converted to strings and injected into the generated regular expression.

This leads to **incorrect glob matching behavior (integrity impact)**, where patterns may match unintended filenames. The issue does **not enable remote code execution**, but it can cause security-relevant logic errors in applications that rely on glob matching for filtering, validation, or access control.

All users of affected ``picomatch`` versions that process untrusted or user-controlled glob patterns are potentially impacted.

Recommendations

Vulnerability affects picomatch [0,2.3.2). Upgrade picomatch to 2.3.2 or higher.

Links

<https://github.com/micromatch/picomatch/commit/4516eb521f13a46b2fe1a1d2c9ef6b20ddc0e903>
<https://github.com/advisories/GHSA-3v7f-55p6-f55p>
<https://github.com/micromatch/picomatch/commit/4516eb521f13a46b2fe1a1d2c9ef6b20ddc0e903>

<https://nvd.nist.gov/vuln/detail/CVE-2026-33672>

<https://nvd.nist.gov/vuln/detail/CVE-2026-33672>

<https://github.com/micromatch/picomatch/security/advisories/GHSA-3v7f-55p6-f55p>

<https://github.com/micromatch/picomatch/security/advisories/GHSA-3v7f-55p6-f55p>

<https://github.com/micromatch/picomatch>

<https://github.com/micromatch/picomatch>

CVE-2026-33671

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-33671
CWE	CWE-1333 , CWE-937 , CWE-1035
GitHub Security Advisory	GHSA-c2c7-rcm5-vvqj
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

`picomatch` is vulnerable to Regular Expression Denial of Service (ReDoS) when processing crafted extglob patterns. Certain patterns using extglob quantifiers such as `+()` and `\*()`, especially when combined with overlapping alternatives or nested extglobs, are compiled into regular expressions that can exhibit catastrophic backtracking on non-matching input.

Examples of problematic patterns include `+(a|aa)`, `+(\*|?)`, `+(+(a))`, `\*+(a)`, and `+(+(+(a)))`. In local reproduction, these patterns caused multi-second event-loop blocking with relatively short inputs. For example, `+(a|aa)` compiled to `^(?:(?=.)?(?:a|aa)+)\$` and took about 2 seconds to reject a 41-character non-matching input, while nested patterns such as `+(+(a))` and `\*+(a)` took around 29 seconds to reject a 33-character input on a modern M1 MacBook.

Applications are impacted when they allow untrusted users to supply glob patterns that are passed to `picomatch` for compilation or matching. In those cases, an attacker can cause excessive CPU consumption and block the Node.js event loop, resulting in a denial of service. Applications that only use trusted, developer-controlled glob patterns are much less likely to be exposed in a security-relevant way.

Recommendations

Vulnerability affects picomatch [0,2.3.2). Upgrade picomatch to 2.3.2 or higher.

Links

- https://github.com/micromatch/picomatch/commit/5eceed27543b8e056b9307d69e105ea03618a7d
- https://github.com/micromatch/picomatch/security/advisories/GHSA-c2c7-rcm5-vvqj
- https://nvd.nist.gov/vuln/detail/CVE-2026-33671
- https://nvd.nist.gov/vuln/detail/CVE-2026-33671
- https://github.com/advisories/GHSA-c2c7-rcm5-vvqj
- https://github.com/micromatch/picomatch/security/advisories/GHSA-c2c7-rcm5-vvqj
- https://github.com/micromatch/picomatch/commit/5eceed27543b8e056b9307d69e105ea03618a7d
- https://github.com/micromatch/picomatch
- https://github.com/micromatch/picomatch

process-nextick-args 2.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	56
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	14.3 %

promise-inflight 1.0.1 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	38
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

pstree.remy 1.1.8 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 58.

Metrics	Security
Popularity	32
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	25.0 %

random-bytes 1.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 50.

❗ There might be a typo, library name resembles randombytes.

Metrics	Security
Popularity	46
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

safer-buffer 2.1.2 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	56
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

set-blocking 2.0.0 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 58.

Metrics	Security
Popularity	56
Authorship assessment	100
Interest in safety	no
Community activity	20
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

setprototypeof 1.2.0 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	60
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	16.7 %

simple-concat 1.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 50.

Metrics	Security
Popularity	46
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	50.0 %

simple-get 4.0.1 MIT

T***

Dependencies found: 3

Dependencies:

- decompress-response 6.0.0
- simple-concat 1.0.1
- once 1.4.0

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 32.

- ❗ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.
- ❗ There might be a typo, library name resembles simple-git.

Metrics	Security
Popularity	98
Authorship assessment	0
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	30.8 %

string-width 4.2.3 MIT

T

Dependencies found: 3

Dependencies:

- is-fullwidth-code-point 3.0.0
- strip-ansi 6.0.1
- emoji-regex 8.0.0

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 44.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

strip-ansi 6.0.1 MIT

T***

Dependencies found: 1

Dependencies:

ansi-regex 5.0.1

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 44.

⚠ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

strip-json-comments 2.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 38.

❗ Unreliable creator. User sindresorhus has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	no
Community activity	60
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

supports-color 5.5.0 MIT

T***

Dependencies found: 1

Dependencies:

■ has-flag 3.0.0

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 44.

❗ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	98
Authorship assessment	0
Interest in safety	no
Community activity	80
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

tar 6.2.1 ISC

T***

Dependencies found: 4

Dependencies:

- chownr 2.0.0
- minizlib 2.1.2
- yallist 4.0.0

■ fs-minipass 2.1.0

Vulnerabilities

CVE-2026-26960

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-26960
CWE	CWE-22,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-83g3-92jg-28cx
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

`tar.extract()` in Node `tar` allows an attacker-controlled archive to create a hardlink inside the extraction directory that points to a file outside the extraction root, using default options.

This enables **arbitrary file read and write** as the extracting user (no root, no chmod, no `preservePaths`).

Severity is high because the primitive bypasses path protections and turns archive extraction into a direct filesystem access primitive.

Recommendations

Links

<https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
<https://nvd.nist.gov/vuln/detail/CVE-2026-26960>
<https://github.com/isaacs/node-tar>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-83g3-92jg-28cx>
<https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
<https://github.com/isaacs/node-tar>
<https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>
<https://github.com/isaacs/node-tar/commit/d18e4e1f846f4dddc153b0f536a19c050e7499f>
<https://github.com/advisories/GHSA-83g3-92jg-28cx>
<https://github.com/isaacs/node-tar/commit/2cb1120bcefe28d7ecc719b41441ade59c52e384>

<https://nvd.nist.gov/vuln/detail/CVE-2026-26960>

CVE-2026-24842

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-24842
CWE	CWE-22,CWE-59,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-34x7-hfp2-rc4v
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

node-tar contains a vulnerability where the security check for hardlink entries uses different path resolution semantics than the actual hardlink creation logic. This mismatch allows an attacker to craft a malicious TAR archive that bypasses path traversal protections and creates hardlinks to arbitrary files outside the extraction directory.

Recommendations

Links

<https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
<https://github.com/isaacs/node-tar/commit/f4a7aa9bc3d717c987fdf1480ff7a64e87ffdb46>
<https://github.com/isaacs/node-tar>
<https://github.com/advisories/GHSA-34x7-hfp2-rc4v>
<https://github.com/isaacs/node-tar>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
<https://nvd.nist.gov/vuln/detail/CVE-2026-24842>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-34x7-hfp2-rc4v>
<https://nvd.nist.gov/vuln/detail/CVE-2026-24842>

CVE-2026-23745

Level **Medium**

Status Not processed

Classification

CVE	CVE-2026-23745
CWE	CWE-22,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-8qq5-rm4j-mr97
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

The `node-tar` library (`<= 7.5.2`) fails to sanitize the `linkpath` of `Link` (hardlink) and `SymbolicLink` entries when `preservePaths` is false (the default secure behavior). This allows malicious archives to bypass the extraction root restriction, leading to **Arbitrary File Overwrite** via hardlinks and **Symlink Poisoning** via absolute symlink targets.

Recommendations

Links

<https://github.com/isaacs/node-tar>
<https://github.com/advisories/GHSA-8qq5-rm4j-mr97>
<https://nvd.nist.gov/vuln/detail/CVE-2026-23745>
<https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
<https://github.com/isaacs/node-tar>
<https://nvd.nist.gov/vuln/detail/CVE-2026-23745>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>
<https://github.com/isaacs/node-tar/commit/340eb285b6d986e91969a1170d7fe9b0face405e>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-8qq5-rm4j-mr97>

CVE-2026-29786

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-29786
CWE	CWE-22,CWE-59,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-qffp-2rhf-9h96
Go Vulnerability Database	null

Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

`tar` (npm) can be tricked into creating a hardlink that points outside the extraction directory by using a drive-relative link target such as `C:/target.txt`, which enables file overwrite outside `cwd` during normal `tar.x()` extraction.

Recommendations

Links

<https://github.com/advisories/GHSA-qffp-2rhf-9h96>
<https://nvd.nist.gov/vuln/detail/CVE-2026-29786>
<https://github.com/isaacs/node-tar>
<https://nvd.nist.gov/vuln/detail/CVE-2026-29786>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>
<https://github.com/isaacs/node-tar/security/advisories/GHSA-qffp-2rhf-9h96>
<https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>
<https://github.com/isaacs/node-tar>
<https://github.com/isaacs/node-tar/commit/7bc755dd85e623c0279e08eb3784909e6d7e4b9f>

CVE-2026-23950

Level **Critical**

Status Not processed

Classification

CVE	CVE-2026-23950
CWE	CWE-176 , CWE-367 , CWE-937 , CWE-1035
GitHub Security Advisory	GHSA-r6q2-hw4h-h46w
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

****TITLE****: Race Condition in node-tar Path Reservations via Unicode Sharp-S (ß) Collisions on macOS APFS

****AUTHOR****: Tomás Illuminati

Recommendations

Links

https://github.com/isaacs/node-tar
https://github.com/advisories/GHSA-r6q2-hw4h-h46w
https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w
https://github.com/isaacs/node-tar
https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcbce0a0df5954d390521e6
https://nvd.nist.gov/vuln/detail/CVE-2026-23950
https://github.com/isaacs/node-tar/commit/3b1abfae650056edfabcbce0a0df5954d390521e6
https://github.com/isaacs/node-tar/security/advisories/GHSA-r6q2-hw4h-h46w
https://nvd.nist.gov/vuln/detail/CVE-2026-23950

CVE-2026-31802

LevelCritical

StatusNot processed

Classification

CVE	CVE-2026-31802
CWE	CWE-22,CWE-937,CWE-1035
GitHub Security Advisory	GHSA-9ppj-qmqm-q256
Go Vulnerability Database	null
Python Packaging Advisory Database	null
RustSec Advisory Database	null

Description

`tar` (npm) can be tricked into creating a symlink that points outside the extraction directory by using a drive-relative symlink target such as `C:../../target.txt`, which enables file overwrite outside `cwd` during normal `tar.x()` extraction.

Recommendations

Links

https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256
https://github.com/isaacs/node-tar/security/advisories/GHSA-9ppj-qmqm-q256
https://nvd.nist.gov/vuln/detail/CVE-2026-31802

https://github.com/advisories/GHSA-9ppj-qmqm-q256
https://github.com/isaacs/node-tar
https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad
https://github.com/isaacs/node-tar
https://nvd.nist.gov/vuln/detail/CVE-2026-31802
https://github.com/isaacs/node-tar/commit/f48b5fa3b7985ddab96dc0f2125a4ffc9911b6ad

tar-stream 2.2.0 MIT

T***

Dependencies found: 4

Dependencies:

- fs-constants 1.0.0
- end-of-stream 1.4.5
- bl 4.1.0
- inherits 2.0.4

Vulnerabilities

Supply Chain Risk	
Level	Medium
Status	Not processed

Description

Dependency score: 52.

⚠️ Unreliable contributors. User `sindresorhus` has expressed strong political opinions.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	yes
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	2.0 %

toidentifier 1.0.1 MIT

Dependecies not found

Vulnerabilities

Supply Chain Risk

LevelMedium

StatusNot processed

Description

Dependency score: 46.

Metrics	Security
Popularity	32
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

tunnel-agent 0.6.0 Apache-2.0

T***

Dependencies found: 1

Dependencies:

■ safe-buffer 5.2.1

Vulnerabilities

Supply Chain Risk

Level Medium

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	84
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	11.1 %

typedarray 0.0.6 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	12
Authorship assessment	100
Interest in safety	no
Community activity	40
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

uid-safe 2.1.5 MIT

T***

Dependencies found: 1

Dependencies:

random-bytes 1.0.0

Vulnerabilities

Supply Chain Risk

Level Medium

Status Not processed

Description

Dependency score: 56.

Metrics	Security
Popularity	76
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

unpipe 1.0.0 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 48.

Metrics	Security
Popularity	44
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

util-deprecate 1.0.2 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	56
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

utils-merge 1.0.1 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Medium
Status	Not processed

Description

Dependency score: 54.

Metrics	Security
Popularity	66
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

whatwg-url 5.0.0 MIT

T***

Dependencies found: 2

Dependencies:

webidl-conversions 3.0.1

tr46 0.0.3

Vulnerabilities

Supply Chain Risk

Level **Medium**

Status Not processed

Description

Dependency score: 58.

Metrics	Security
Popularity	100
Authorship assessment	0
Interest in safety	yes
Community activity	60
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	38.2 %

wrappy 1.0.2 ISC

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level

Medium

Status

Not processed

Description

Dependency score: 52.

Metrics	Security
Popularity	64
Authorship assessment	100
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	33.3 %

xtend 4.0.2 MIT

Dependencies not found

Vulnerabilities

Supply Chain Risk

Level	Critical
Status	Not processed

Description

Dependency score: 18.

- ❗ Unreliable contributors. User `medikoo` has expressed strong political opinions. User `medikoo` seen in intentional malware implementation.

Metrics	Security
Popularity	92
Authorship assessment	0
Interest in safety	no
Community activity	0
Recently created library	no
First version suspiciously high	no
Only project by this developer	no
% of pull requests violate the 2-person review requirement	0.0 %

Scan Settings

2/2 2026-05-18 04:31:25

ARCHIVE

Authorization

- ☐ Basic access authentication
- ☐ Authentication token
- ☐ Ssh Key
- ☒ Software Composition Analysis
- ☒ Supply Chain Analysis
- ☒ License Risk Analysis
- ☒ Save the uploaded file

03

Export Settings

Project Information

Project Statistics

- ☒ Dynamics by Security
- ☒ Dynamics by vulnerabilities

Scan History

- ☐ Do not export scan history
- ☒ Export entire scan history
- ☐ Export the latest scans ...

Scan Information

- ☒ Detected vulnerabilities chart
- ☒ Vulnerable dependencies diagram
- ☒ Scan settings

Vulnerability Filter

Severity

- ☒ Critical
- ☒ Medium
- ☐ Low
- ☐ Info

List of dependencies

- ☒ Vulnerable dependencies
- ☐ Safe dependencies

Extra

- ☐ With a task created in Jira

Vulnerability Types

- ☒ Vulnerabilities
- ☒ Supply Chain Risks
- ☒ License Risks

Vulnerability List

Vulnerability Statuses

- ☒ Not processed
- ☒ Confirmed
- ☐ Rejected

List of Dependency Vulnerabilities

- ☐ Do not export
- ☒ Export all entries
- ☐ Export no more than entries ...

Analysis Results

Vulnerability Statuses

- ☒ Not processed
- ☒ Confirmed
- ☐ Rejected

Extra

- ☒ Vulnerability comment
- ☒ Vulnerability actions
- ☒ Jira information

General Report Settings

- ☒ Table of contents
- ☒ Report export settings
- ☒ Display vulnerability statuses